Assessment 01: Security Foundations

EWB Courses - AI-Powered Cybersecurity

Name	Batch / Group	Date
Adnan	Cybersecurity Batch	October 2026

I only used the fictional data given in the assessment. No real systems, passwords or personal data were used.

Task A: Secure a student account

A1 and A2: Risks and controls

Risk	Asset	CIA impact	Control	Limitation
1. Same short password on email and portal	Email and portal accounts	**C:** if one password leaks, both accounts are open. **I:** someone could change her data.	Use a different long password for each account and keep them in a password manager.	If the manager's master password is stolen, everything is exposed.
2. Approving sign-in prompts she did not start	Account access	**C and I:** an attacker gets in because Mira approved it herself.	Deny and report unknown prompts. Use number-matching MFA.	She still has to notice the prompt is fake.
3. Delaying device updates	Laptop and the data on it	**C, I and A:** old bugs let malware or ransomware steal, change or lock files.	Turn on automatic updates and restart often.	Does not protect against bugs nobody knows about yet.
4. Only copy of the project is on one laptop	Project files	**A:** if the laptop is lost or breaks, the work is gone. **I:** corruption may go unnoticed.	Keep one copy in the cloud and one on an external drive.	Sync can copy deleted files too, and backups need to be tested.
5. A friend uses the laptop on her signed-in account	Her accounts and files	**C:** the friend can read private things. **I:** actions look like they came from Mira.	Lock the screen when away and give the friend a guest account.	Does not help if the friend knows her password.

My top three actions

1. **Unique passwords.** The biggest problem is that one leak opens both accounts, and this is free and quick to fix.
2. **Deal with MFA prompts properly.** MFA is her second layer, but approving unknown prompts cancels it out.
3. **Stop her friend using her signed-in account.** It gives instant access to everything with no record of who did what.

Backups and updates come after these because they mainly reduce the damage later, they do not stop someone getting in now.

A3: Authentication vs authorisation

Authentication is proving who you are. On the learning portal, Mira does this with her password and the MFA approval. Authorisation is what you are allowed to do after that. Mira can see her own courses and submit her own work, but she cannot change other students' grades or open admin pages. The two are linked: if an attacker logs in as Mira, they get everything Mira is allowed to do.

Task B: Analyse a suspicious message

B1: Five warning signs

Phrase from the message	Why it looks suspicious
"FINAL WARNING - scholarship expires in 20 minutes"	It rushes you so you do not stop to check.
From: awards@campus-awards.example	The college uses campus.example, so this is a different, similar-looking domain.
Reply-To: help@personal-awards.example	Replies would go to a third domain that does not match the college or the sender.
"enter your college password and OTP"	Attackers need both to log in as you. Real staff do not ask for these.
"Do not contact the college office"	It tries to stop you from checking if the message is real.

The request to send a photo of an identity card is also a worry, since it asks for personal data by email.

B2 and B3: Verification and response plan

How to verify safely

1 Do not click the link or reply to the message.

2 Find the official contact myself, using the college website typed in the browser, a bookmark, or the number on official notices.

3 Ask the scholarship or accounts office if I really got an award and if they sent this.

4 Forward the message to the college IT team as suspected phishing.

HTTPS only means the connection is encrypted. Attackers can get HTTPS for their own fake domains, so a padlock does not prove the sender is real. A display name like "Scholarship Desk" is just text anyone can type, so that does not prove it either.

If a student already entered the password and OTP

1 **Contain it:** use a trusted device to open the official portal (typed or bookmarked) and change the password. Sign out of all other devices.

2 Check the MFA devices and recovery options, and change the same password anywhere else it was used.

3 **Report:** tell the college IT team and office through official contacts. Keep the message as evidence and do not delete it. Mention it if an ID photo was sent.

4 **Follow up:** check recent sign-ins, mail forwarding rules and account settings, and watch out for more phishing.

5 Never send the password or OTP to anyone, even someone helping.

B4: What I cannot tell from the message alone

I cannot prove that the sender or website is actually malicious, or who owns those domains. The message has many warning signs, but that is not proof. More evidence that would help: the full email headers (SPF, DKIM, DMARC results), confirmation from the scholarship office that no such award exists, and a safe check of the domains by IT staff.

Task C: Triage a sign-in alert

C1: Timeline

Time (IST)	What the logs / user say (observed)	What I think it means
09:00-09:01	Password success and MFA approved from 192.0.2.10, the usual classroom IP.	A normal login. It matches the user saying they did not sign in after 09:05.
10:14-10:16	From 198.51.100.23: two failed passwords, then one success.	Could be guessing or a known password, but a new IP alone does not prove an attacker.
10:17-10:18	MFA denied, then approved. The user says they approved a prompt around 10:18 to stop repeated requests.	Looks like MFA fatigue: many prompts until the user approved one.
10:20	Session created from 198.51.100.23.	There is probably a session the user did not knowingly start, so the account may be compromised.

C2: Explanations and checks

Likely: someone got or guessed the password, kept sending MFA prompts, and the user's approval let them in. **Alternative:** the user signed in from another network, like mobile data or a VPN, and does not remember. An IP address does not identify a person, so I cannot be sure either way.

Two checks:

1 Compare the device, browser and network of the 10:20 session with student07's usual devices, and ask if they used mobile data or a VPN.

2 Look at what the session did after 10:20 and whether the same IP shows up for other users.

C3: Response actions for the IT team

1 **Protect the account:** end active sessions, force a password reset through a verified channel, and set up MFA again (number-matching if possible). This is first because a session may still be live.

2 **Keep the evidence:** export and store the login logs, session records and MFA prompt history, and write down the user's statement. Do this at the same time and do not delete or edit logs.

3 **Find the scope:** check what happened since 10:20, look for the same IP on other accounts, consider blocking or monitoring it, and remind the user not to approve prompts they did not start.

C4: Incident summary

At 10:14-10:20 IST on 18 October 2026, student07's account had two failed then one successful password attempt from 198.51.100.23, then an MFA denial, an MFA approval and a new session. The user says they did not sign in after 09:05 and approved a prompt to stop repeated requests. This fits a compromised password plus MFA fatigue, but the IP cannot confirm who it was. Priority: high. Next step: IT should end the session, reset credentials, save the logs and review account activity.

Task D: Review an AI security answer

D1: Five problems and corrections

What the AI said	Correction
"The email is safe because it uses HTTPS."	HTTPS only encrypts the connection and does not show who sent the email. The message has a lookalike domain, a mismatched Reply-To, urgency and a request for password and OTP (Task B). CISA says to verify through official channels.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Logs show events from an IP address, not a person, and not how a password was obtained. The pattern is suspicious but it is not proof.
"MFA prevents every account compromise."	MFA helps a lot but not always. The logs show an approval after repeated prompts (MFA fatigue).
"Delete the suspicious logs."	Logs are evidence. Deleting them makes it harder to understand the incident, so they should be kept and protected.
"Send the student's password to support so they can test it."	Passwords should never be shared and real support does not need them. The password should be treated as compromised and reset.

The AI sounds very sure about things it cannot know. NIST AI 600-1 calls this confabulation and says AI answers need to be checked against evidence.

D2: Better prompt

> You are helping with a training exercise. Use ONLY the fictional evidence I paste below. It has no real student data. Do not ask me for passwords, OTPs, ID photos or other secrets. (1) List the observed facts and quote the evidence. (2) List your assumptions separately and label them. (3) Give the most likely explanation and at least one alternative. (4) Say what cannot be known and what extra evidence would help. (5) Suggest safe, prioritised actions for an authorised IT team, including keeping evidence. Say how confident you are (low/medium/high), do not say an IP address identifies a person, and tell me if you are unsure instead of guessing. [PASTE SYNTHETIC EVIDENCE HERE]

D3: My corrected advice

> Do not trust a message just because it uses HTTPS, because that does not show who sent it. Check the sender domain and Reply-To, and confirm through the official portal or a contact you found yourself. The sign-in logs look suspicious, but they cannot prove who used 198.51.100.23 or that a password was stolen, so treat the account as possibly compromised until checked. MFA lowers the risk but is not perfect, so never approve a prompt you did not start. Keep the logs as evidence and never delete them. Never share your password or OTP with anyone, including support. Reset the password the official way, end active sessions, check MFA devices and report it to IT.

D4: AI-use declaration and references

AI-use declaration: I used an AI tool (Claude, by Anthropic) to help draft and structure my answers. I read and edited them and checked them against the scenario and the references below. I did not enter any real passwords, OTPs or personal data.

Reference notes:

1 CISA, *Secure Our World* (https://www.cisa.gov/secure-our-world): basic advice on strong unique passwords, MFA, updates and spotting and reporting phishing. Supports Tasks A, B and D1.

2 NIST, *Generative AI Profile, AI 600-1* (https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf): explains confabulation (confident but wrong AI output) and why AI answers must be verified. Supports Task D.